

unwanted software. It may be far easier to set up a safe server using Linux, but that does not explain the success of these worms.

Purists may object that most vulnerabilities occur in applications and not necessarily in the operating system. That is true—but what about cross-platform applications that are now in vogue? Apache can now run on BSD, Mac's OS X, Linux and just about every other platform out there. In a famous hack sometime ago, a bunch of clever hackers attacked apache.org to show that a mis-configured Apache server can lead to serious security vulnerabilities. Ken Thompson's famous compiler hack (www.acm.org/classics/sep95/) again goes to show that one piece of software (in this case, GCC) being used everywhere can lead to system-wide vulnerabilities.

If there is gloom about the state of diversity in computer systems, is there a flip side? Using numerous little known, obscure and out-of-date software does not automatically guarantee security. The goal is to use the right software for

Ken Thompson's famous compiler hack shows that using one piece of software everywhere can lead to system-wide vulnerabilities

the right job. Tailor each configuration to a particular need; don't assume that the default is right. Don't use one setup or configuration because it may seem easy to administer or maintain. Security is a trade-off between functionality and safety. Understand the need for diversity in the context of the systems that you are in contact with.

Yes, there are advantages to a software or operating system being used by a large number of people. Widespread use results in better testing and detection of potential problems. In communities that can react quickly to problems (for example, the Linux community solved the Ping-Of-Death bug in two hours), the widespread use of software implies that it can quickly become safer. So, is there a middle path to choose?

For the Windows world, the simplest option would be to not upgrade unless you absolutely need to. If your current browser displays pages decently, do you really need that new version? Especially if you have been diligently applying all

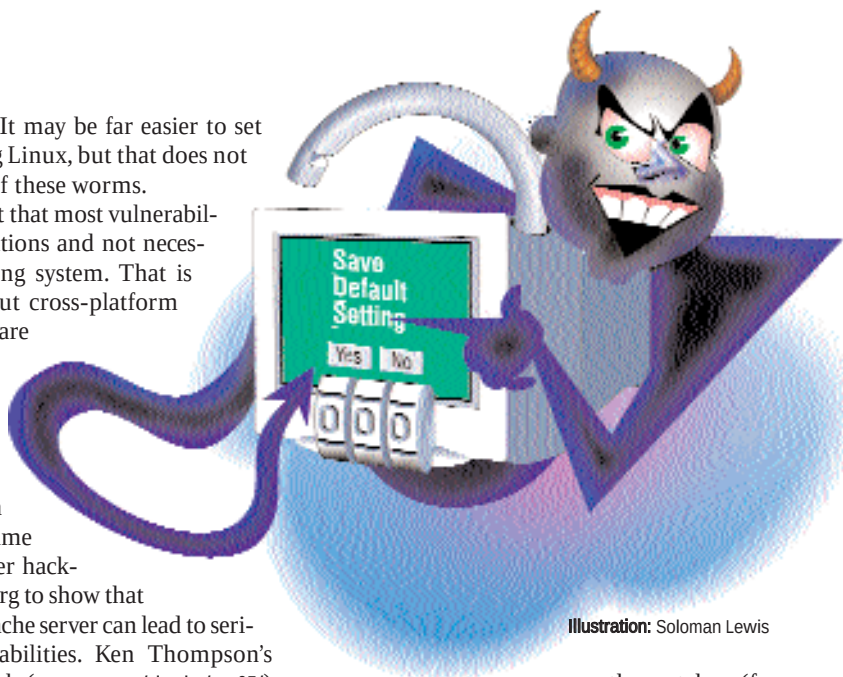


Illustration: Solomon Lewis

the patches (from <http://windowsupdate.microsoft.com/>) for your current setup? Use some of the available freeware firewalls to mask your identity. For the Linux world, do not use the default install—customise each machine based on its requirements. Use a hardening script like Bastille Linux (www.bastille-linux.org/) to kill known security issues. Turn off services that you do not need.

One very interesting possibility is the IP-Personality Patch (<http://ippersonality.sourceforge.net/>) available for Linux Kernel 2.4. This patch makes your machine look like any other operating system to external scanners—so you can make your Linux machine pretend to be an OS/2, Windows, FreeBSD or Sun Solaris box! This way, you can have your cake and eat it too! You can use a popular distribution (and the attendant benefits) while pretending to be a rare, and therefore difficult to attack, platform.

A heterogeneous network in an office or organisation will need more work and maintenance. It may also need more resources and personnel. But in the larger perspective, if you want a more reliable and fault tolerant setup, then diversity is strength. Learn to mix and match OSes, software and resources. Depending on your needs, use different configurations wherever justified. Try to introduce an awareness of where each software has a particular niche in which it is most suited. Apart from learning about different software and how they interact, this will expose you to potential overlaps between software—something that is useful from a security perspective. More importantly, learning how to use different software keeps you from becoming normal and ordinary—and normal is boring, right? ■

Madhu Kurup works for the data engineering group at the Yahoo! Software Development Center, Bangalore. He can be contacted at madhumkurup@yahoo.com